

BÁO CÁO

**Giám sát và cảnh báo cho toàn bộ lỗ hổng bảo mật với
các sản phẩm công nghệ**

Văn phòng Tập đoàn Điện lực Việt Nam

Hà Nội, 11/2025

CyRadar Threat Intelligence Platform

BÁO CÁO TUẦN 44

Giám sát và cảnh báo cho toàn bộ lỗ hổng bảo mật với các sản phẩm công nghệ

Văn phòng Tập đoàn Điện lực Việt Nam

Đơn vị được giám sát	Văn phòng Tập đoàn Điện lực Việt Nam
Địa chỉ	Số 11 phố Cửa Bắc, Phường Trúc Bạch, Quận Ba Đình, thành phố Hà Nội, Việt Nam.
Thời gian giám sát	2025/10/28 12:10:00 – 2025/11/04 12:10:00
Đơn vị triển khai	Công ty Cổ phần An toàn Thông tin CyRadar
Phân loại tài liệu	Giới hạn

MỤC LỤC

TỔNG QUAN.....	4
KHUYẾN NGHỊ KHẮC PHỤC	7
PHỤ LỤC 1. GIÁM SÁT CẢNH BÁO CHO TOÀN BỘ ĐỊA CHỈ IP PUBLIC	8
PHỤ LỤC 2. TÀI SẢN GIÁM SÁT	14

TỔNG QUAN

Hệ thống CyRadar Threat Intelligence thực hiện giám sát tài sản của Văn phòng Tập đoàn Điện lực Việt Nam nhằm đưa ra các cảnh báo về nguy cơ an ninh mạng trong hệ thống khách hàng.

Phạm vi giám sát:

Sản phẩm	
Windows server 2008	Apache Tomcat
Windows server 2012	Glassfish
Windows server 2016	IIS
Windows server 2019	.NET
Windows 10	Junos
Microsoft Office 2016	PAN-OS
Oracle 12c	Cisco OS
Oracle 11g	Esxi
Centos 7	VMware
Aix 7.1	SolarWinds
Aix 7.3	Zoom
Sun Solaris 11.2	F5 Big-IP
Sun Solaris 11.3	Gitlab
Oracle SQL	Blue Coat
Microsoft SQL 2014	Forcepoint
Microsoft SQL 2016	Symantec
Microsoft SQL 2019	Kemp LoadMaster
Exchange 2016	Azure devops server 2020

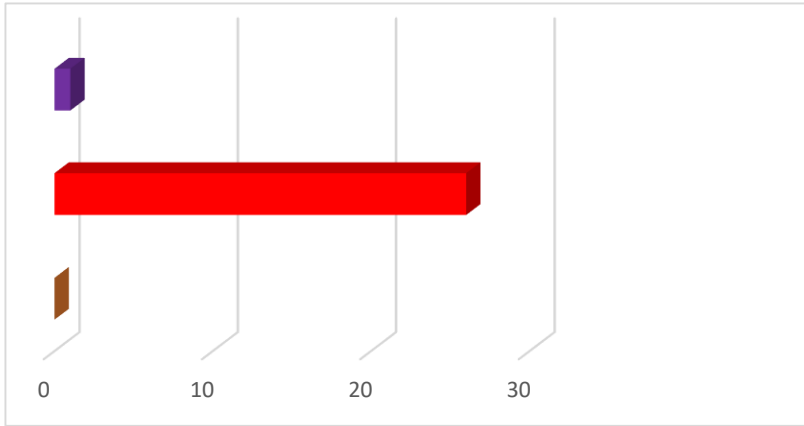
Sản phẩm	
Symantec Endpoint Protection	Atlassian Confluence
Jira	Manageengine servicedesk plus
Firefox	Apache
Microsoft SharePoint	

Báo cáo này bao gồm kết quả giám sát đánh giá về các nguy cơ, mô tả chi tiết các vấn đề đã phát hiện cùng các khuyến nghị để xử lý khắc phục vấn đề.

Thông tin tổng quan

Nguy cơ 595 -27.97 %	Lộ lọt tài khoản 134 +12.61 %	Lộ lọt thẻ tín dụng 0 N/A
Lộ lọt tài liệu 0 N/A	Lạm dụng thương hiệu 0 N/A	Botnet 0 N/A
Yêu cầu điều tra 0 / 0 N/A	Chiến dịch tấn công 0 / 8 N/A	Cổng dịch vụ đang mở 17 -46.88 %

Lỗ hổng bảo mật

Mức độ	Phát hiện	Biểu đồ								
Nghiêm trọng	1	 <table><thead><tr><th>Mức độ</th><th>Phát hiện</th></tr></thead><tbody><tr><td>Nghiêm trọng</td><td>1</td></tr><tr><td>Cao</td><td>26</td></tr><tr><td>Trung bình</td><td>0</td></tr></tbody></table>	Mức độ	Phát hiện	Nghiêm trọng	1	Cao	26	Trung bình	0
Mức độ	Phát hiện									
Nghiêm trọng	1									
Cao	26									
Trung bình	0									
Cao	26									
Trung bình	0									

KHUYẾN NGHỊ KHẮC PHỤC

Lỗ hổng bảo mật

- Cập nhật bản vá mới nhất từ nhà cung cấp
- Đối với lỗ hổng nguy hiểm, nếu chưa thể vá, tạm thời vô hiệu hóa tính năng chứa lỗ hổng
- Tăng cường bảo vệ và giám sát bằng Firewall, IDS/IPS, SIEM...
- Ghi log đầy đủ và lưu trữ để phục vụ điều tra sau này
- Kiểm tra lại hệ thống sau xử lý để đảm bảo an toàn

Lộ lọt dữ liệu (thông tin tài khoản, tài liệu, thẻ tín dụng)

- Xác minh dữ liệu bị lộ lọt
- Xử lý khắc phục tùy loại dữ liệu: đổi mật khẩu, vô hiệu hóa API key, khóa thẻ tín dụng, xử lý sự cố truyền thông, thông báo tới khách hàng...
- Khoanh vùng, điều tra nguyên nhân lộ lọt
- Rà soát, làm sạch nguy cơ gây lộ lọt trong hệ thống
- Tăng cường áp dụng các chính sách về ATTT trong nội bộ (phân quyền truy cập, yêu cầu bật xác thực đa lớp, định kỳ đổi mật khẩu, sử dụng phần mềm chống mã độc...)

Bị lạm dụng thương hiệu

- Thông báo tới khách hàng của tổ chức không truy cập vào các tên miền/đường dẫn lừa đảo
- Phối hợp với các cơ quan chức năng để ngăn chặn các tên miền lừa đảo

Liên quan Malware/Botnet

- Xác định và cách ly hệ thống bị nghi nhiễm khỏi mạng nội bộ
- Thu thập logs & dấu vết (IOC) phục vụ điều tra
- Quét toàn bộ hệ thống bằng công cụ Antivirus/EDR và thực hiện rà soát thủ công bằng chuyên gia để đảm bảo phát hiện, gỡ bỏ hoàn toàn mã độc
- Thay đổi mật khẩu của các tài khoản liên quan
- Điều tra đường tấn công, và khắc phục vấn đề
- Giám sát hoạt động mạng chặt chẽ sau khi xử lý

PHỤ LỤC 1. GIÁM SÁT CẢNH BÁO CHO TOÀN BỘ ĐỊA CHỈ IP PUBLIC

CÁC SẢN PHẨM, PHẦN MỀM ỨNG DỤNG

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
1	Microsoft/ Windows 10	CVE-2025-59199	Cao	Kiểm soát truy cập không đúng cách trong Nền tảng bảo vệ phần mềm (SPP) cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-59195	Cao	Việc thực thi đồng thời bằng cách sử dụng tài nguyên được chia sẻ có đồng bộ hóa không đúng ('tình trạng tương tranh') trong Thành phần Microsoft Graphics cho phép kẻ tấn công được ủy quyền từ chối dịch vụ cục bộ.	Cập nhật bản vá
		CVE-2025-55701	Cao	Việc xác thực không đúng loại đầu vào được chỉ định trong Microsoft Windows cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-58714	Cao	Kiểm soát truy cập không đúng cách trong Trình điều khiển chức năng phụ trợ của Windows cho WinSock cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-58715	Cao	Tràn số nguyên hoặc bao quanh trong Microsoft Windows Speech cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-55692	Cao	Xác thực đầu vào không đúng cách trong Báo cáo lỗi Windows cho phép kẻ tấn	Cập nhật bản vá

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
				công được ủy quyền nâng cao đặc quyền cục bộ.	
		CVE-2025-59193	Cao	Việc thực thi đồng thời bằng cách sử dụng tài nguyên được chia sẻ có đồng bộ hóa không đúng ('điều kiện chạy đua') trong Dịch vụ quản lý Windows cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-55696	Cao	Điều kiện chạy đua thời gian sử dụng (toctou) thời gian kiểm tra trong chức năng Mã thông báo NtQueryInformation (ntifs.h) cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-55689	Cao	Sử dụng sau khi miễn phí trong Windows PrintWorkflowUserSvc cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-58718	Cao	Việc sử dụng miễn phí trong Remote Desktop Client cho phép kẻ tấn công trái phép thực thi mã qua mạng.	Cập nhật bản vá
		CVE-2025-59196	Cao	Việc thực thi đồng thời bằng cách sử dụng tài nguyên được chia sẻ có đồng bộ hóa không đúng ('tình trạng chùng tộc') trong Dịch vụ SSDP của Windows cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
		CVE-2025-58716	Cao	Xác thực đầu vào không đúng cách trong Microsoft Windows Speech cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
2	Microsoft/ Windows Server	CVE-2025-55701	Cao	Việc xác thực không đúng loại đầu vào được chỉ định trong Microsoft Windows cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-58714	Cao	Kiểm soát truy cập không đúng cách trong Trình điều khiển chức năng phụ trợ của Windows cho WinSock cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
		CVE-2025-58718	Cao	Việc sử dụng miễn phí trong Remote Desktop Client cho phép kẻ tấn công trái phép thực thi mã qua mạng.	Cập nhật bản vá
		CVE-2025-59196	Cao	Việc thực thi đồng thời bằng cách sử dụng tài nguyên được chia sẻ có đồng bộ hóa không đúng ('tình trạng chung tộc') trong Dịch vụ SSDP của Windows cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền cục bộ.	Cập nhật bản vá
3	Mozilla/ Firefox Focus	CVE-2025-10537	Cao	Các lỗi an toàn bộ nhớ có trong Firefox ESR 140.2, Thunderbird ESR 140.2, Firefox 142 và Thunderbird 142. Một số trong những lỗi này cho thấy bằng chứng về tham nhũng bộ nhớ và chúng tôi cho rằng với đủ nỗ lực, một số trong số này có thể đã được khai thác để chạy mã tùy ý.	Cập nhật bản vá

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
				Lỗ hổng này ảnh hưởng đến Firefox <143, Firefox ESR <140.3, Thunderbird <143 và Thunderbird <140.3.	
		CVE-2025-2857	Nghiêm trọng	Sau lỗi thoát Sandbox Chrome gần đây (CVE-2025-2783), các nhà phát triển Firefox khác nhau đã xác định một mẫu tương tự trong mã IPC của chúng tôi. Một quá trình con bị xâm phạm có thể khiến quá trình cha mẹ trả lại một tay cầm vô tình mạnh mẽ, dẫn đến một lỗi thoát Sandbox. Lỗ hổng ban đầu đã được khai thác trong tự nhiên.*Điều này chỉ ảnh hưởng đến Firefox trên Windows. Các hệ điều hành khác không bị ảnh hưởng.* Lỗ hổng này ảnh hưởng đến Firefox <136.0.4, Firefox ESR <128.8.1 và Firefox ESR <115.21.1.	Cập nhật bản vá
		CVE-2025-2817	Cao	Cơ chế cập nhật của Thunderbird cho phép quy trình người dùng tích hợp trung bình can thiệp vào trình cập nhật cấp hệ thống bằng cách thao tác với hành vi khóa tệp. Bằng cách đưa mã vào quy trình quyền của người dùng, kẻ tấn công có thể bỏ qua các điều khiển truy cập dự định, cho phép các hoạt động tệp cấp hệ thống trên các đường dẫn được điều khiển bởi người dùng không đặc quyền và cho phép	Cập nhật bản vá

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
				leo thang đặc quyền. Lỗ hổng này ảnh hưởng đến Firefox <138, Firefox ESR <128.10, Firefox ESR <115,23, Thunderbird <138 và Thunderbird <128.10.	
		CVE-2025-1936	Cao	JAR: URL truy xuất nội dung tệp cục bộ được đóng gói trong kho lưu trữ zip. NULL và mọi thứ sau khi nó bị bỏ qua khi truy xuất nội dung từ kho lưu trữ, nhưng phần mở rộng giả sau khi null được sử dụng để xác định loại nội dung. Điều này có thể đã được sử dụng để ẩn mã trong một tiện ích mở rộng web được ngụy trang như một thứ khác giống như một hình ảnh. Lỗ hổng này ảnh hưởng đến Firefox <136, Firefox ESR <128.8, Thunderbird <136 và Thunderbird <128.8.	Cập nhật bản vá
4	Gitlab/Gitlab	CVE-2025-11989	Cao	GitLab đã khắc phục một sự cố trong GitLab EE ảnh hưởng đến tất cả các phiên bản từ 17.6.0 trước 18.3.5, 18.4 trước 18.4.3 và 18.5 trước 18.5.1 có thể đã cho phép kẻ tấn công đã được xác thực để thực hiện các hành động nhanh trái phép bằng cách đưa các lệnh độc hại vào các mô tả cụ thể.	Cập nhật bản vá
		CVE-2025-11702	Cao	GitLab đã khắc phục một sự cố trong EE ảnh hưởng đến tất cả các phiên bản từ 17.1 trước 18.3.5, 18.4 trước 18.4.3 và 18.5 trước 18.5.1. Sự cố này có thể cho phép kẻ tấn công được xác thực với các	Cập nhật bản vá

#	Sản phẩm	Điểm yếu, lỗ hổng	Mức độ	Mô tả	Khuyến nghị
				quyền cụ thể để chiếm quyền điều khiển người chạy dự án từ các dự án khác.	
5	Microsoft/ Sharepoint Server	CVE-2025-59228	Cao	Xác thực đầu vào không đúng cách trong Microsoft Office SharePoint cho phép kẻ tấn công được ủy quyền thực thi mã qua mạng.	Cập nhật bản vá
		CVE-2025-59237	Cao	Việc hủy tuần tự hóa dữ liệu không đáng tin cậy trong Microsoft Office SharePoint cho phép kẻ tấn công được ủy quyền thực thi mã qua mạng.	Cập nhật bản vá
6	Microsoft/ Exchange Server	CVE-2025-59249	Cao	Xác thực yếu trong Microsoft Exchange Server cho phép kẻ tấn công được ủy quyền nâng cao đặc quyền qua mạng.	Cập nhật bản vá
		CVE-2025-59248	Cao	Xác thực đầu vào không đúng cách trong Microsoft Exchange Server cho phép kẻ tấn công trái phép thực hiện giả mạo qua mạng.	Cập nhật bản vá
7	Microsoft/ Office	CVE-2025-59234	Cao	Việc sử dụng sau khi miễn phí trong Microsoft Office cho phép kẻ tấn công trái phép thực thi mã cục bộ.	Cập nhật bản vá

PHỤ LỤC 2. TÀI SẢN GIÁM SÁT

Thông tin sản phẩm

#	Tài sản	Mô tả
1	Centos 7.0	
2	Database Server 12c	
3	Database Server 11g	
4	Office 2016	
5	windows_10	
6	office 2016	
7	Exchange Server 2016	
8	Sql Server 2014	
9	Aix 7.1	
10	Aix 7.3	
11	Firefox Focus	
12	Tomcat	
13	Sql Server 2019	
14	Sql Server 2016	
15	Glassfish	
16	Azure Devops Server 2020	
17	blue_coat_authentication_and_authorization_agent	
18	loadmaster	
19	asp.net_core	
20	iis	
21	junos	
22	gitlab	

23	vmware	
24	zoom	
25	manageengine_servicedesk_plus	
26	Windows Server 2012	
27	Solaris 11.3	
28	windows_server 2008	
29	pan-os	
30	Solaris 11.2	
31	esxi	
32	sharepoint_server	
33	Confluence	
34	message_gateway 10.7.5-4	
35	message_gateway 10.9.0-3	
36	Symantec Endpoint Protection 14.3	
37	jira	
38	mysql	
39	ios	
40	Tmos	
41	solarwinds_platform 2025.1.1	
42	security_manager	
43	Http Server	

Thông tin định danh

#	Tài sản	Loại
1	Evn	Keyword
2	evnlearning	Keyword